IC26

infocomm AMÉRICA LATINA

Cuando IT frena tu proyecto AV

Seguridad que se diseña, no se parcha

22 de octubre de 2026 · WTC, Ciudad de México

Parte 1: Juan Pineda · Service Delivery Manager / Tech Academy Lead · Pyxis
Parte 2: Eduardo Travi · Business Development Manager, CTS · AVI SPL

pyxis

AVI SPL

¿Qué vamos a hacer en estos 90 minutos?

Parte 1 · 45 minutos

Juan Pineda · Pyxis

- Por qué IT frena un proyecto AV: el marco de seguridad y el ciclo de vida de un ataque.
- Mini demos en vivo sobre una red aislada que montamos en la sala.

Parte 2 · Prueba de concepto

Eduardo Travi · AVI SPL

- Un caso real con SIP: cómo fugas pequeñas se combinan y terminan en un phishing dirigido.
- De la teoría a la práctica, demostrado en vivo.

No necesitas laptop: participas desde tu teléfono, sobre nuestra propia red WiFi.
Puedes seguir sin instalar nada; el escáner de red es opcional. El kit se descarga después.

Antes de empezar: uso responsable

Escanear o probar sistemas sin autorización escrita del dueño es un delito.
Ni en el recinto, ni en tu empresa, ni en la de un cliente. Hoy, solo sobre la red aislada del laboratorio.
Colombia: Ley 1273 de 2009, art. 269A · Argentina: Ley 26.388, art. 153 bis · México: Código Penal Federal, arts. 211 bis 1 a 7

Fines educativos
Todo lo que ves hoy es para aprender a diseñar y defender instalaciones AV.

Capturas de ejemplo
Las imágenes de las demos son ilustrativas; no corresponden a ningún cliente ni sistema real.

Opiniones propias
Criterio de los presentadores; no representa a fabricantes ni a los organizadores. Las marcas se omiten a propósito.

El kit
Es para practicar en tu propio entorno de laboratorio.

Esto no es asesoría legal: consulta la legislación vigente de tu país.



Tu proyecto AV está listo.
Entonces IT lo revisa y lo frena.

El problema no es tu diseño. Es que la seguridad se pensó al final, no desde el día uno.

pyxis

ic26 infocomm AMÉRICA LATINA

Los pecados que IT ve en tu rack

Interfaces sin autenticación

Paneles y APIs abiertos a cualquiera en la red.

Ej.: el panel del códec sin clave.

Credenciales de fábrica

admin / admin en equipos carísimos.

Ej.: la contraseña que nunca se cambió.

Protocolos legacy y sin cifrar

mDNS, Telnet, HTTP plano: tráfico al descubierto.

Ej.: mDNS anunciando el equipo a todos.

Firmware y software viejo

Versiones con vulnerabilidades conocidas, sin parchar.

Ej.: un CVE público del modelo exacto.

Sin visibilidad

Ni logs ni monitoreo: nadie ve lo que pasa.

Ej.: un acceso raro que nadie registra.

Acceso físico al rack

Diez segundos frente al equipo alcanzan.

Ej.: un puerto libre en el switch.

Son las vulnerabilidades comunes que describe AVIXA RP-C303.01, §5.2.

Lo que IT ve cuando mira tu equipo AV

Lo que ves tú	Lo que ve IT
Un códec. **Un DSP.** **Un controlador.** Un equipo AV que hace su trabajo.	• Un sistema operativo. • Servicios de red y puertos abiertos. • A veces, salida a internet. • Un host que ellos no administran.

Por eso no desconfían de ti. Desconfían de un host desconocido en su red.

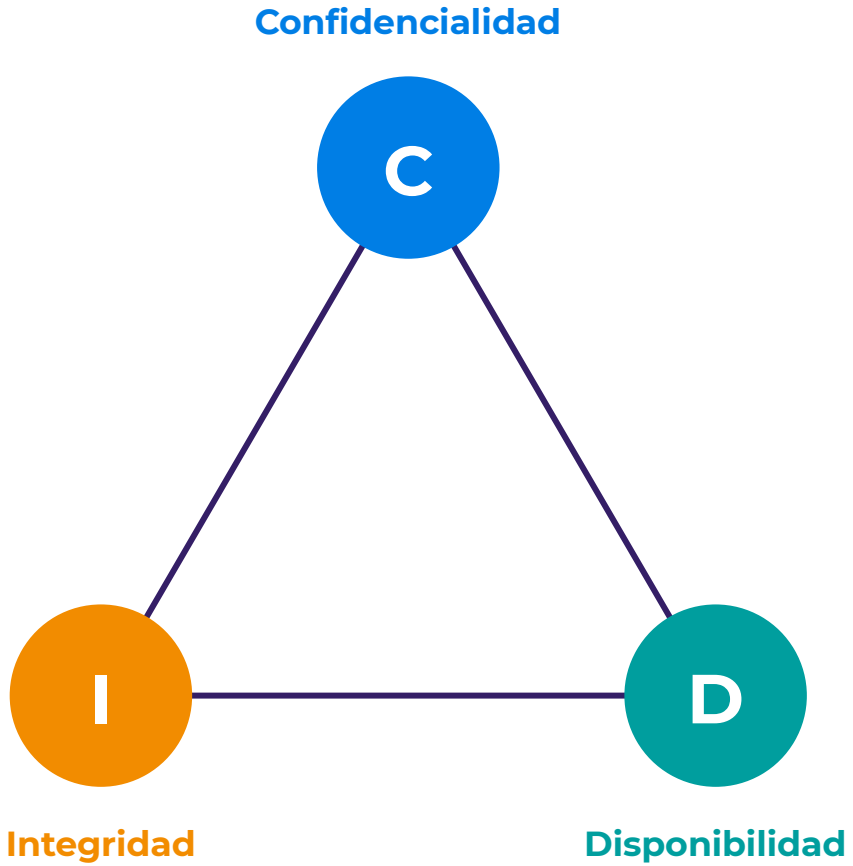
infocomm AMÉRICA LATINA

Las capas de red: OSI y TCP/IP



mDNS y paneles viven en la 7; IT segmenta en 2 y 3; el cifrado cubre 4 a 6.
nmap enumera la capa 4 y Wireshark lee de la 2 a la 7. Las dos, en las demos.

Marco 1: la tríada CIA



C **Confidencialidad**
Que la señal y las credenciales no las vea quien no debe.
Ej.: streaming sin cifrar.

I **Integridad**
Que nadie altere lo emitido ni la configuración.
Ej.: firmware sin firmar.

D **Disponibilidad**
Que el sistema esté cuando se lo necesita.
Ej.: la sala del directorio, caída en vivo.

Marco 2: la hexada de Parker

Donn Parker amplió la tríada con tres elementos más. Dos de ellos pesan mucho en AV.

C — Confidencialidad
Ya vista: que no lo vea quien no debe.

I — Integridad
Ya vista: que nadie lo altere.

D — Disponibilidad
Ya vista: que esté cuando se necesita.

CLAVE EN AV

P — Posesión o control
Que el equipo siga bajo tu control. Ej.: quien tiene el rack, tiene el equipo.

CLAVE EN AV

A — Autenticidad
Que lo que llega sea de quien dice ser. Ej.: ¿este firmware es del fabricante?

U — Utilidad
Que la información sirva. Ej.: una grabación cifrada cuya clave se perdió.

Cada marco mira el mismo problema con más detalle. El siguiente lo organiza como lo hace IT.

Marco 3: NIST CSF 2.0

Gobernar	Identificar	Proteger	Detectar	Responder	Recuperar
Quién responde por la seguridad del equipo.	Qué dispositivos hay y qué exponen.	Segmentar, cifrar, mínimo privilegio.	Logs y monitoreo: saber cuándo pasa algo.	Qué se hace ante un incidente.	Cómo se vuelve a operar.

El integrador toca sobre todo Identificar y Proteger.

Marco 4: defensa en profundidad

Defensa en profundidad

Varias capas de protección: si una falla, el ataque no llega al final.

CAPA 1 **Mínimo privilegio**	CAPA 2 **Segmentación**	CAPA 3 **Cifrado**	CAPA 4 **Credenciales gestionadas**
Cada equipo y usuario, solo lo que necesita.	El AV en su propia red, aparte de corporativa e invitados.	Control y señal protegidos en tránsito, no en texto plano.	Nada de admin/admin; cuentas administradas y rotadas.

Son las mismas capas que vamos a ver atacadas, paso a paso, en el resto de la sesión.



Por qué IT es tan restrictivo: porque conoce el ciclo de vida de un ataque.

No hace falta un atacante sofisticado. Hace falta una cadena de descuidos pequeños. Veamos esa cadena.

pyxis

ic26 infocomm AMÉRICA LATINA

Mapa 1: el ciclo de vida de un ataque

Cyber Kill Chain (Lockheed Martin): las 7 etapas.



Mapa 2 — MITRE ATT&CK detalla cada etapa en tácticas y técnicas. Lo vemos enseguida.

No hace falta un atacante sofisticado.

Hace falta una cadena de descuidos pequeños. La recorremos con demos, cada una con su táctica ATT&CK.

Mapa 2: MITRE ATT&CK

MITRE ATT&CK Base de conocimiento de comportamientos reales de atacantes.

Táctica = el QUÉ
El objetivo que el atacante quiere conseguir en un momento dado.

Técnica = el CÓMO
El método que usa para lograrlo. Las subtécnicas son sus variantes.

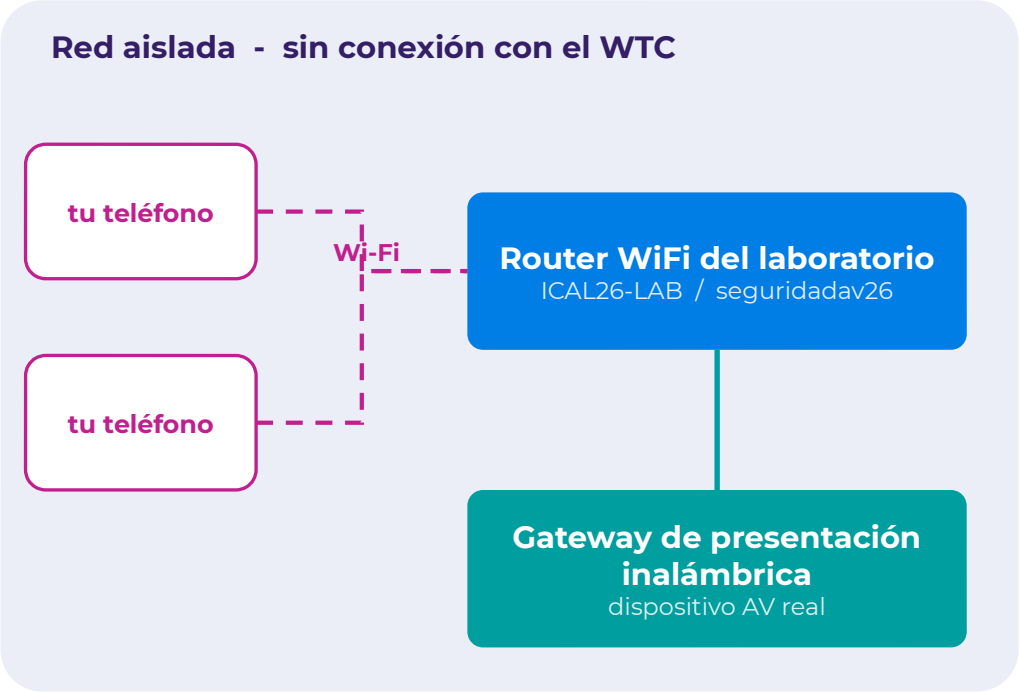
Las 14 tácticas de ATT&CK Enterprise. Resaltadas, las 4 que recorremos hoy:

Reconnaissance	Resource Dev.	Initial Access	Execution	Persistence	Priv. Escalation	Defense Evasion
Credential Access	**Discovery**	**Lateral Movement**	Collection	Command & Control	Exfiltration	Impact

Resaltadas: Reconnaissance (nmap), Discovery (Wireshark), Credential Access y Lateral Movement. · Fuente: MITRE ATT&CK · IBM Think

infocomm AMÉRICA LATINA

Manos a la obra: conéctate al laboratorio



Para participar

1. Conéctate a la red ICAL26-LAB (clave: seguridadav26).
2. Opcional, para ir más a fondo: instala un escáner de red. En el teléfono, Fing o Network Scanner; en laptop, nmap.
3. Escanea y mira lo que aparece. Seguimos la demo juntos.

Regla de oro
Escanea SOLO la red del laboratorio. Nunca la red del recinto (WTC): eso es intrusión.

Demo 1: reconocimiento con nmap

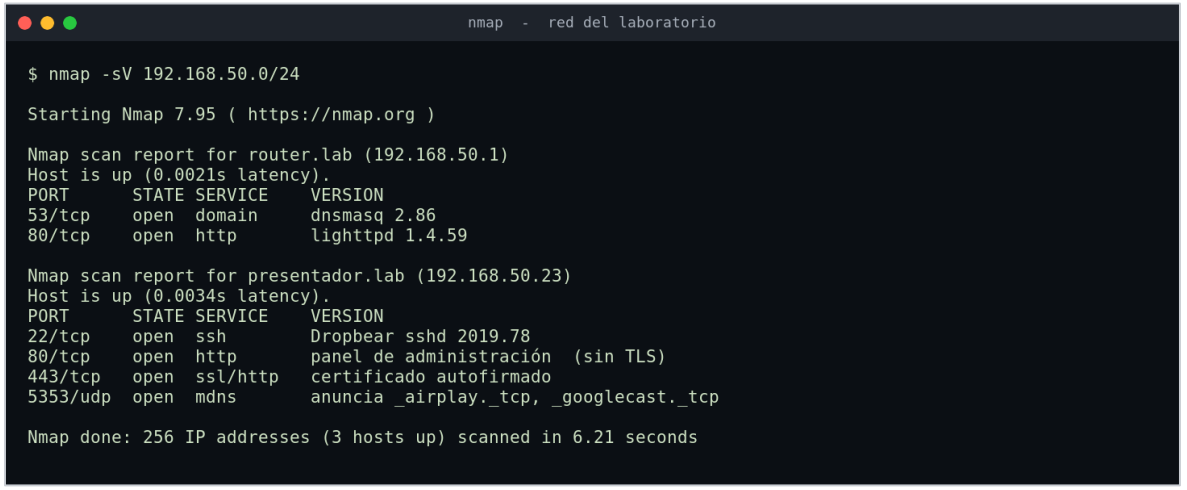
ATT&CK - Reconnaissance (TA0043)

Desde la red aislada, un escaneo revela cada host, sus puertos y sus servicios.

En segundos aparece el mapa completo: qué hay, qué versión corre, qué está expuesto.

El atacante no necesita entrar todavía. Solo mirar. Y ya sabe por dónde.

Si quieres, lo corres tú también desde tu teléfono, sobre la red del laboratorio.



Ejemplo representativo: salida de nmap sobre la red del laboratorio

Demo 2: protocolos de casa (mDNS)

ATT&CK - Discovery (TA0007)

mDNS, AirPlay y compañía fueron diseñados para la red de tu casa: anuncian todo, sin autenticar.

Con Wireshark vemos a los equipos AV gritando su nombre, modelo y servicios a toda la red.

Es una de las razones principales por las que IT frena un proyecto AV.

Wireshark - wlan0 - filtro: mdns

No.	Time	Source	Destination	Protocol	Length	Info
12	0.000000	192.168.50.23	224.0.0.251	MDNS	318	Standard query response 0x0000 PTR _airplay._tcp.local Presentador-SalaJuntas
13	0.000412	192.168.50.23	224.0.0.251	MDNS	292	Standard query response 0x0000 TXT model=presenter-gw fw=2.6.1 features=0x5A7FFFF7
14	0.003118	192.168.50.44	224.0.0.251	MDNS	101	Standard query 0x0000 PTR _googlecast._tcp.local "QM" question
15	0.003590	192.168.50.23	224.0.0.251	MDNS	264	Standard query response 0x0000 SRV Presentador-SalaJuntas._airplay._tcp.local port 7000
16	0.010204	192.168.50.1	224.0.0.251	MDNS	88	Standard query 0x0000 PTR _services._dns-sd._udp.local
17	0.011877	192.168.50.23	224.0.0.251	MDNS	240	Standard query response 0x0000 A Presentador-SalaJuntas.local 192.168.50.23

Ejemplo representativo: captura de Wireshark con tráfico mDNS del gateway de presentación

Fugas que, sumadas, dan contexto

Hostname y modelo
marca y tipo de equipo

Nombres de salas
organigrama y ubicaciones

Versión de firmware
vulnerabilidades conocidas

Agenda y directorio
nombres y correos reales

Correo de phishing dirigido
creíble, porque usa datos reales

De: Soporte TI <soporte@empresa-que-no-es.com>
Para: Mariana López, Gerencia

Asunto: Fallo en el gateway de la Sala de Juntas

Hola Mariana, el equipo de la Sala de Juntas tiene la versión 2.6.1 con un fallo conocido. Ingresa con tu usuario para aplicar el parche antes de tu reunión de las 10.

Nada es grave por separado. Combinado, es el guion de un ataque dirigido.

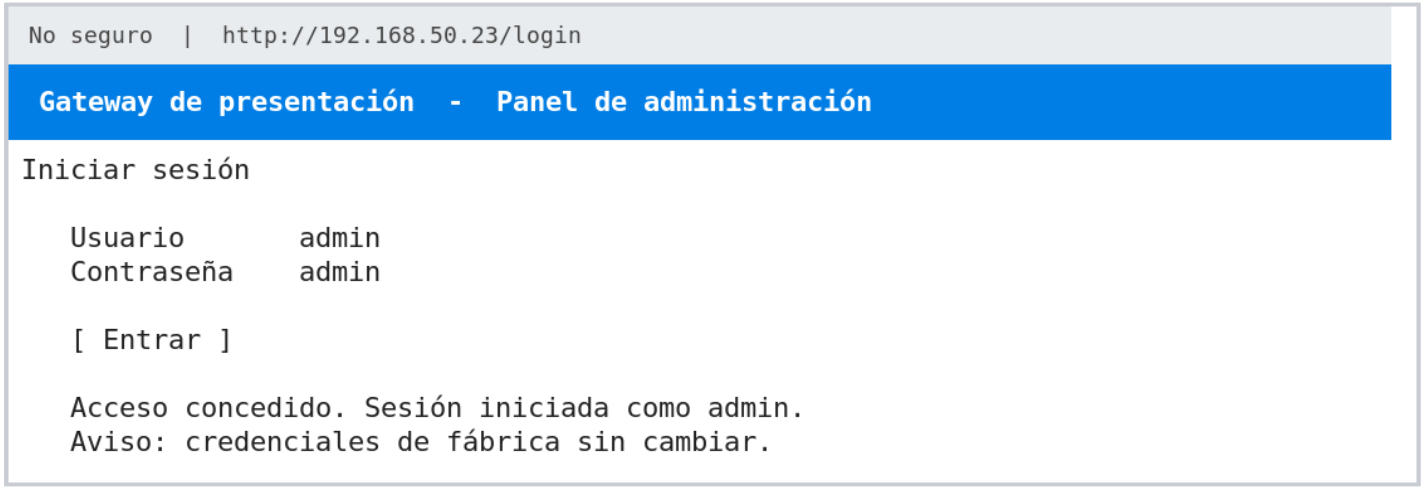
Acceso inicial: la puerta ya estaba abierta

ATT&CK - Initial Access / Credential Access

Muchos equipos AV se instalan y se dejan con la credencial de fábrica.

admin/admin, o sin contraseña, en el panel web de control.

Desde ahí se lee la configuración, la agenda, los contactos y a veces se controla el equipo.



Ejemplo representativo: panel de administración del equipo con credencial de fábrica



El objetivo no era apagar la pantalla.
Era el correo de phishing que ahora es creíble.

Con nombres, cargos, salas y agenda reales, el atacante escribe un correo que el destinatario no duda en abrir. Eso es lo que está en juego.

pyxis

ic26 infocomm AMÉRICA LATINA

Lo que dice AVIXA

AVIXA RP-C303.01

Prácticas recomendadas de seguridad en sistemas AV en red. Todo lo que sigue está ahí.

Identidad y acceso

Cambiar la contraseña de fábrica antes de instalar; 12 caracteres o más; roles de administrador y usuario.

§7.1

Parches y firmware

Proceso definido; probar la actualización antes de aplicarla y saber qué cambia.

§7.2

Cifrado

Si hay HTTPS, apagar HTTP. Sin TLS 1.1 ni SSLv3. Datos personales cifrados.

§7.3

Puertos y servicios

Documentar entrantes y salientes; apagar lo que no se usa, como Telnet o FTP.

§7.4, §7.7

VLAN propia para AV

Separada de la corporativa; hacia ella solo por router con ACL. 802.1X o MAB.

§7.5

Documentar y acordar

Inventario, topología con VLAN y ACL, roles. Responsabilidades por escrito con IT.

§9.1, §9.2

ANSI/AVIXA D402.02 añade el cuándo: se verifica en integración, post-integración y cierre.

Es el estándar del gremio. Pedirlo no es ser exigente: es cumplirlo.

Qué proponer: seguridad por fase del proyecto

Diseño

- Segmentación en el plano, no después.
- Requisitos de seguridad en el pliego.
- Equipos que soporten TLS y cuentas gestionadas.

Implementación

- Cambiar las credenciales de fábrica.
- Apagar servicios sin uso y cifrar el control.
- Actualizar firmware antes de entregar.

Entrega

- Documentar puertos y servicios.
- Dejar logs activos hacia IT.
- Acordar quién mantiene el firmware.

La seguridad se diseña desde el día uno. No es un parche que se agrega al final.

ANSI/AVIXA D402.02 formaliza esta verificación por fase: pre-integración, integración, post-integración y cierre.

Segmentación: la propuesta que IT quiere escuchar

VLAN AV
dispositivos AV aislados

VLAN de control
plano de gestión separado

Firewall con reglas explícitas: solo lo necesario pasa · AVIXA RP-C303.01 §7.5

De control a AV
gestión cifrada (SSH, HTTPS)

De corporativa a AV
solo lo acordado: calendario, directorio

De invitados a AV
bloqueado

Visibilidad: IT suele poner un sensor que escucha el tráfico de la VLAN AV sin tocar los equipos (en su jerga, un NIDS).

Red corporativa
datos de la empresa

Red de invitados
el visitante, nunca el AV

Todo lo demás, bloqueado. Es la propuesta que IT quiere escuchar.

Secure by default: checklist de hardening

Seguro por defecto, no por pedido
El equipo sale de tu mano ya endurecido. No esperas a que IT lo exija.

1

Credenciales

Cambiar las de fábrica y retirar las temporales de la instalación; cuentas administradas.

2

Superficie

Apagar servicios y protocolos sin uso: Telnet, mDNS, UPnP.

3

Firmware

Actualizar y acordar quién lo mantiene en el tiempo.

4

Cifrado

Control y gestión cifrados; nada de HTTP plano ni Telnet.

5

Visibilidad

Dejar logs activos y enviarlos a donde IT los vea.

Cinco cosas antes de entregar. Si el cliente no las pide, las haces igual.
Alineado con la línea base de seguridad de AVIXA RP-C303.01, §7.

Las preguntas que IT te va a hacer (y cómo responder)

¿Qué puertos abre este equipo?	Lista documentada de puertos y servicios.
¿En qué red va a estar?	En la VLAN AV, segmentada, con reglas explícitas.
¿Cómo se gestionan las credenciales?	Cuentas administradas; nada de fábrica.
¿Cómo actualizamos y monitoreamos?	Plan de firmware y logs hacia su sistema de monitoreo (en su jerga, SIEM).

Tener esto listo convierte la revisión de IT en un trámite, no en un freno.

Es la documentación que pide AVIXA RP-C303.01 §9.2: puertos y servicios, topología con VLAN y ACL, roles y permisos.

Cuando el cliente no tiene políticas formales

Muchos clientes no tienen un área de seguridad madura. Ahí el integrador marca la diferencia.

Lleva tú el mínimo

Segmentación, credenciales, cifrado y logs.

Como estándar, no como extra.

Documéntalo

Hazlo parte de la entrega.

Protege al cliente y te protege a ti.

Conviértelo en diferencial

No es un costo: es tu ventaja comercial.

Es lo que te distingue frente a otro integrador.

Eres el integrador que entrega seguro por defecto.

Para llevar: marcos y herramientas

Estándares AVIXA

AVIXA RP-C303.01
Prácticas recomendadas de seguridad en sistemas AV en red. La línea base de este taller.
avixa.org/standards

ANSI/AVIXA D402.02
Verificación de desempeño de sistemas AV, por fases del proyecto.
avixa.org/standards

Marcos

NIST CSF 2.0
Marco de gestión de riesgo que usa IT.
nist.gov/cyberframework

MITRE ATT&CK
Catálogo de tácticas y técnicas reales.
attack.mitre.org

Cyber Kill Chain
Las fases de un ataque (Lockheed Martin).
lockheedmartin.com/.../cyber-kill-chain

CIS Controls v8.1
18 controles priorizados para implementar.
cisecurity.org/controls

Herramientas y lecturas

Nmap
Escaneo de red y de servicios.
nmap.org

Wireshark
Análisis de tráfico (mDNS y más).
wireshark.org

MITRE ATT&CK explicado
Qué es una táctica y una técnica (con video).
ibm.com/think/mitre-attack

En el kit descargable:
Checklist de hardening, guía del laboratorio y guion de preguntas de IT.

De la teoría a la práctica: la prueba de concepto con SIP.

Eduardo Travi, de AVI SPL, continúa con la prueba de concepto sobre telefonía SIP.

Headline Partner: AVI SPL

Patrocinador Gold: audio-technica

infocomm AMÉRICA LATINA

La evolución de la sala: de la caja anónima al nodo de identidad

Ayer (2011): la caja anónima

- Marcación directa por IP (H.323 / SIP plano).
- Cuentas genéricas, sin autenticación de usuario.
- Audio y video aislados del resto del negocio.
- Riesgo percibido por IT: bajo. Un electrodoméstico más.

Hoy (2026): el nodo de identidad corporativa

- Autenticación por identidad del usuario y por tokens.
- Integración nativa con agentes de IA y asistentes corporativos.
- Accede a datos sensibles según el perfil de quien inicia sesión.
- Riesgo real: acceso lateral a modelos y repositorios de datos.

Si no validamos la identidad de los extremos, no sólo arriesgamos la llamada:
abrimos la puerta a los agentes de IA y a los datos a los que ellos acceden.

La trampa del integrador: ni negligencia ni bloqueo ciego

Extremo 1: negligencia por comodidad

- Desactivar cifrados (SRTP / TLS) para evitar demoras.
- APIs de automatización abiertas y con credenciales por defecto.
- Redes de sala sin validación ni inspección.

El rol del integrador moderno

- La IA y la nube llegaron a la sala sin pedir permiso.
- Nuestro valor no es bloquear ni ser laxos:
- es diseñar con los marcos de IT (CIA, NIST) desde el plano inicial.

Extremo 2: seguridad por oscuridad

- Desconectar el equipo o prohibir la integración con IA.
- Bloqueos ciegos que frustran la adopción del usuario.
- Soluciones que degradan la productividad del negocio.

Ni candados que impidan trabajar ni puertas abiertas: seguridad desde el diseño.

El concepto del «goteo»: cómo se arma un ataque dirigido

Información pública (OSINT)

- Redes profesionales: organigramas, directivos, jerarquías.
- Proveedores habituales de TI, soporte y marcas usadas.

Información de la red interna

- Puertos y servicios expuestos en el segmento.
- Dispositivos de sala que responden sin autenticación previa.

Información de los dispositivos AV

- Agendas corporativas guardadas en la memoria del equipo.
- Historial reciente de llamadas y hábitos de reunión.

Nada es grave por separado. Combinado, es el guion de un ataque dirigido.

Es el mismo «goteo» que vimos en la parte 1, ahora demostrado en vivo.

Topología del laboratorio: la VLAN de sala expuesta

Servidor SIP (192.168.0.191)
Proxy de señalización interno.

Teléfono de escritorio (192.168.0.21)
Interno administrativo / Finanzas (ext. 1320).

Terminal de VC de sala (192.168.0.79)
Códec de la sala de directorio (ext. 1340).

Laptop (técnico) (192.168.0.45)
Conectada a una boca de red de la sala.

Premisa de diseño equivocada

«La VLAN AV es privada; por eso no necesita certificados ni cifrado estricto.»

Veamos qué pasa cuando asumimos que una red privada es, por eso mismo, una red segura.

Demo 1: reconocimiento y topología

Fase Kill Chain · Reconocimiento (sin credenciales de red)

Servidor SIP (192.168.0.191)
Proxy SIP escuchando en el puerto 5060.

Teléfono de escritorio (192.168.0.21)
Interno administrativo / Finanzas (ext. 1320).

Terminal de VC de sala (192.168.0.79)
Códec de directorio: SIP + puertos 22 y 24 abiertos.

Laptop (técnico) (192.168.0.45)
Punto de observación en el segmento.

Comando de auditoría de red

```
nmap -sS -sU -p 22,24,80,443,5060 192.168.0.0/24
```

Un escaneo revela la topología completa: el proxy SIP y el códec de sala, sin una sola credencial.

Demo 2: señalización en claro (análisis de tráfico)

Fase Kill Chain · Explotación de la confianza implícita

La vulnerabilidad

- SIP plano sobre UDP (puerto 5060): encabezados, identidades y extensiones viajan legibles.
- Negociación de medios (SDP) sin claves criptográficas (RTP/AVP).

Lo que falta

- Sin SIP sobre TLS: nada cifra la señalización.
- Sin mTLS: el proxy acepta el registro de cualquier softphone en el 5060.
- Ausencia de validación criptográfica de la identidad del equipo.

Diseñar sin exigir TLS deja la identidad y la señalización al descubierto.

Demo 3: el «goteo» de inteligencia local

Fase Kill Chain · Recolección de datos

Lo que el equipo entrega	Por qué importa
• La libreta de contactos completa del códec (p. ej. 20 directivos). • El historial reciente de llamadas: con quién, a qué hora y cuánto duró.	• Identifica con precisión a la dirección y a la mesa de ayuda de TI. • Confirma actividad reciente: con quién acaba de sesionar la sala.

Un códec que entrega su agenda por una API sin proteger completa el «goteo».
Lo evitan credenciales robustas y la API restringida por IP.

Demo 4: armado del vector (suplantación de identidad)

Fase Kill Chain · Armado del vector

La suplantación

- Un softphone estándar con el nombre visible «Soporte AV».
- Una dirección SIP tomada de la propia agenda de la empresa.

La falla que lo permite

- El proxy reenvía la señalización confiando en el origen.
- La red no desafía a un equipo que dice representar a «Soporte».

No hace falta malware ni un día cero: basta la confianza implícita en «la red interna».

Demo 5: acción sobre el objetivo (pretexto telefónico)

Fase Kill Chain · Acción sobre el objetivo · Ingeniería social

Lo que ve la sala

- La pantalla muestra una llamada entrante de «Soporte AV».
- Audio nítido y bidireccional, como cualquier llamada legítima.

Por qué el engaño funciona

- Un pretexto creíble: una supuesta falla de audio en la sesión anterior.
- Confianza ciega: el usuario asume que el aviso en pantalla es legítimo.

Con datos reales y un identificador falso, el pretexto telefónico resulta convincente.
La cadena técnica terminó quebrando la seguridad de la sala.

Remediación: defensa en profundidad, etapa por etapa

De la Kill Chain al control técnico que la evita

Escaneo de red	Control de acceso 802.1X + microsegmentación.
Fuga de agenda por API	Credenciales robustas + API restringida por IP.
Señalización SIP en claro	SIP sobre TLS (puerto 5061) obligatorio.
Suplantación de softphone	Certificados mutuos de máquina (mTLS).
Audio sin cifrar	SRTP / AES configurado como «requerido».

Cada etapa se neutraliza desde el diseño. No es presupuesto: es criterio.

La nueva postura del integrador AV

De técnicos de equipamiento a garantes de la seguridad y la identidad corporativa

1. Hablar el idioma de IT
Diseñar con marcos formales (CIA, NIST, Zero Trust) desde la primera reunión con el cliente.

2. Habilitar sin exponer
Proteger la infraestructura para que los agentes de IA y las salas operen con gobernanza.

3. Responsabilidad compartida
La frontera entre AV y ciberseguridad desapareció: la sala es un nodo de cómputo crítico.

Seguridad diseñada desde el día cero. Ése es el socio estratégico que IT quiere.

InfoComm AMÉRICA LATINA

Llévate el kit

1. **Checklist de hardening**
   Para auditar tus proyectos antes de que IT los revise.

2. **Guía para montar tu laboratorio**
   Red aislada y USB de arranque para practicar en casa.

3. **Guion de preguntas de IT**
   Con las respuestas que te dejan pasar la revisión.

Escanea para descargar el kit

Juan Pineda · Pyxis

juan.pineda@pyxis.tech

linkedin.com/in/jdpinedac

Eduardo Travi · AVI SPL

Eduardo.Travi@avispl.com

linkedin.com/in/eduardotravi

infocomm AMÉRICA LATINA